CB-SAFE: Code-Based Post-Quantum Secure Aggregation for Byzantine-Robust Federated Learning

Md Wahiduzzaman Suva and Esm-e Moula Chowdhury Abha

***Abstract*—Secure aggregation protects federated learning (FL) updates by revealing only their sum, but its key establishment breaks under a quantum adversary, and post-quantum FL today derives confidentiality almost exclusively from lattice assumptions, a single point of cryptanalytic failure. We present CB-SAFE, to our knowledge the first FL secure-aggregation framework whose post-quantum confidentiality is established by a code-based KEM (HQC, selected by NIST in March 2025 to diversify away from lattices) rather than a lattice KEM. CB-SAFE treats the KEM as a pluggable module: the same double-masking protocol runs over HQC or ML-KEM, and per-round mask seeds are derived from long-lived encapsulated secrets, so the KEM affects only a one-time setup. Measured on a 291 498-parameter model with 30 clients, per-round traffic is KEM-independent (2 277 KiB per client), and the entire code-based premium is a one-time 15.2 vs. 3.8 KiB per client at NIST level 1 (49.4 vs. 7.7 KiB at level 5), under 0.03% of the traffic of a single training round. CB-SAFE further reconciles secure aggregation with Byzantine robustness by aggregating securely *within* clusters of c clients and applying robust rules (trimmed mean, median, Multi-Krum) *across* the revealed cluster sums, and we quantify the resulting privacy–robustness tension: the anonymity set grows with c while the probability a cluster sum stays uncontaminated decays as $(1-f)^c$ under malicious fraction f. We prove a simulation-based privacy theorem, identify a *laundering* effect by which cluster averaging turns amplified sign-flip poisoning into plausible-magnitude inverted sums that defeat all coordinate-wise robust rules, and introduce CB-SAFE+: re-randomized clustering with root-anchored direction flags accumulates per-client suspicion across rounds (temporal group testing over private sums) and excludes attackers the server never observes individually, at zero additional leakage. Experiments across three datasets and two modalities (non-IID CIFAR-10 and FashionMNIST, and tabular Edge-IIoTset IoT intrusion detection) with label-flipping, sign-flipping, and backdoor attacks validate the framework: the laundering effect and CB-SAFE+'s recovery replicate on every dataset (CB-SAFE+ beats every baseline under sign-flip, Holm-corrected $p<0.01$), and the implementation is released open-source.**

***Index Terms*—Post-quantum cryptography, federated learning, secure aggregation, HQC, code-based cryptography, Byzantine robustness, cryptographic diversity.**

I. INTRODUCTION

FEDERATED learning (FL) trains a shared model across many clients without centralizing data [24], [25], but the transmitted model updates leak private information: gradient-inversion [26], [27] and membership- or model-inversion [28], [29] attacks reconstruct training samples from individual updates. Secure aggregation closes this channel by ensuring the server observes only the *sum* of updates, using pairwise additive masks that cancel on aggregation [1], [12]; recent designs reduce its overhead [31], [32], though the sum itself can still leak [30]. The confidentiality of those masks rests on key establishment that Shor's algorithm [33] breaks once a cryptographically relevant quantum computer exists, and traffic recorded today can be decrypted then ("harvest-now, decrypt-later").

The standard response replaces classical key exchange with a post-quantum KEM, and nearly all post-quantum FL does so with *lattice* cryptography [4]–[7], [17]. Lattices are efficient and standardized (ML-KEM, FIPS 203 [3]), but concentrating an entire ecosystem's confidentiality on one hardness assumption is a systemic risk: a single cryptanalytic advance would break every such deployment simultaneously. NIST recognized exactly this risk when, in March 2025, it *selected* the code-based KEM HQC (whose security reduces to syndrome decoding of quasi-cyclic codes [35], not to lattice problems, in the tradition of code-based cryptography since McEliece [34]) as a diversified backup to ML-KEM [2]. That diversity has not reached federated learning.

A second, orthogonal tension is that secure aggregation and Byzantine robustness pull in opposite directions: hiding individual updates denies the server exactly the visibility that poisoning defenses need. Recent work combines robustness with *lattice*-based post-quantum aggregation [7], or achieves cluster-based robust aggregation on *quantum hardware* [8]; no prior framework provides both under a code-based, classical post-quantum assumption.

This paper presents CB-SAFE (Code-Based Secure Aggregation for Federated lEarning), making four contributions:

1) **A KEM-agnostic secure-aggregation protocol** (Definition 1) that formalizes Bonawitz-style double masking over any IND-CCA2 KEM, with per-round mask seeds derived from long-lived encapsulated secrets so key encapsulation is a one-time cost. The post-quantum primitive becomes a single replaceable module.
2) **The first code-based instantiation, scope-qualified:** to our knowledge, CB-SAFE is the first FL secure-aggregation framework whose post-quantum confidentiality comes from the NIST-selected code-based KEM

M. W. Suva (ID 26-94088-2) and E. M. C. Abha (ID 26-94089-2) are with the Department of Computer Science, American International University-Bangladesh, Dhaka, Bangladesh (e-mail: wshuvo360@gmail.com).

Manuscript prepared August 2026. Source code and artifacts are available at the project repository.

(HQC) rather than a lattice KEM, at matched NIST security levels.

3) **A quantified reconciliation of privacy and robustness:** secure aggregation *within* clusters of c clients, robust aggregation (trimmed mean, median, Multi-Krum) *across* cluster sums, and an explicit trade-off law (the anonymity set is c while the clean-cluster probability decays as $(1-f)^c$) validated experimentally under three attacks. We further identify and analyze a *laundering* effect: cluster averaging turns amplified sign-flip poisoning into plausible-magnitude, direction-inverted cluster sums that defeat every coordinate-wise robust rule (Proposition 1).
4) **CB-SAFE+, a defense that identifies hidden attackers:** per-round re-randomized clustering plus direction flags against a small server root dataset accumulate per-client suspicion (temporal group testing over privacy-preserving observations) and exclude malicious clients the server has never observed individually. The flags are post-processing of already-revealed cluster sums, so the defense adds *no* leakage beyond CB-SAFE itself (Theorem 1).
5) **An honest, measured cost analysis:** on a 291k-parameter model, per-round traffic is KEM-independent and the full code-based premium is a one-time 15.2 KiB vs. 3.8 KiB per client (NIST level 1), i.e., under 0.03% of one round's traffic; HQC's $\sim$200$\times$ slower operations contribute about 2 s (one-time, 30 clients) versus 0.02 s for ML-KEM.

TABLE I
SUMMARY OF NOTATION.

Symbol	Meaning
N	total number of clients
c	cluster size (anonymity set)
$k = N/c$	number of clusters per round
f	fraction of malicious clients
m	malicious members in a given cluster
d	model dimension (parameters)
α	Dirichlet concentration (label skew)
$\mathbf{x}_i$	local update of client i
$q(\cdot)$	fixed-point quantization (2^{-16}/coord.)
$\mathbf{y}_i$	masked submission of client i
$\mathcal{K}$	KEM $(\mathsf{KeyGen}, \mathsf{Encaps}, \mathsf{Decaps})$
ss_{ij}	pairwise KEM shared secret (i, j)
H, G	key-derivation function, PRG
b_i^r	self-mask seed of i in round r
t	Shamir threshold $\lfloor c/2 \rfloor + 1$
$\mathbf{S}_\ell$	mean of cluster ℓ revealed to server
γ	sign-flip amplification factor
γ^*	laundering boundary $2c/m - 1$
$\mathbf{h}$	honest update direction
$\boldsymbol{\mu}$	contaminated cluster mean
β	trim fraction per side (robust rule)
$\mathcal{D}_0$	server root dataset ($\lvert\mathcal{D}_0\rvert$=200)
$L(\cdot; \mathcal{D}_0)$	root loss probe
g_ℓ^r	flag bit of cluster ℓ in round r
s_i^r	accumulated suspicion of client i
p_h	honest co-cluster flag prob. $1-(1-f)^{c-1}$
τ	exclusion threshold
o	overlap degree (groups per client)
R	number of training rounds
ASR	backdoor attack success rate

II. Related Work

Post-quantum FL is lattice-dominated. PQSF reconstructs masks with lattice multi-stage secret sharing [4]; Qin and Xu build single-round aggregation from a lattice key-homomorphic PRF [5]; Narsimhulu *et al.* aggregate Dilithium-style lattice signatures [6]; and a 2026 framework combines reputation-weighted Byzantine-robust aggregation with Kyber/lattice-based secure aggregation for IoT threat intelligence [7]. Surveys confirm lattice dominance across post-quantum deployment [17]. Non-lattice exceptions are rare and code-free: multivariate cryptography with blockchain [9], and CQSA, which partitions clients into clusters aggregated via GHZ states on near-term *quantum hardware* [8]. CB-SAFE differs from all of the above on the confidentiality assumption: syndrome decoding of quasi-cyclic codes, via a standard-track classical KEM [2], with the KEM exposed behind an agnostic interface so lattice and code-based variants differ in exactly one module.

Byzantine robustness and poisoning. Model- and data-poisoning attacks [21], [22], [39], including stealthy [37] and backdoor [15], [38] variants, and their defenses are a large literature: robust aggregation rules such as Multi-Krum [13], coordinate-wise trimmed mean and median [14], Bulyan [19], and the geometric-median aggregator RFA [20]; trust-bootstrapped filtering (FLTrust [10], Zeno [11]); malicious-client detection (FLDetector [40]); and backdoor-specific defenses (FLAME [23]). These operate on *individual* client updates, which secure aggregation deliberately hides, creating the privacy–robustness tension we address.

Cluster-based robust aggregation. Reconciling Byzantine resilience with secure aggregation is an established goal: BREA does so through secret-shared distance computation [16], CQSA through clustered aggregation on quantum hardware [8], and, closest to our robustness mechanism, FedGT [18] identifies malicious clients by group testing over overlapping secure-aggregation groups. Aggregating within groups and inspecting group sums is thus a known structure; our contribution is not the cluster topology itself but (i) its first classical post-quantum, code-based instantiation and (ii) an explicit, experimentally validated statement of the privacy–robustness trade-off it induces (Section III-D), with a temporal group-testing defense (CB-SAFE+) that matches FedGT's attacker identification at far lower false-positive cost, and scales past FedGT's fixed small-population design.

III. The CB-SAFE Framework

A. Notation

We use lowercase bold for vectors and uppercase bold for matrices. The server coordinates N clients grouped into clusters of size c; a fraction f is malicious. Table I summarizes the symbols used throughout.

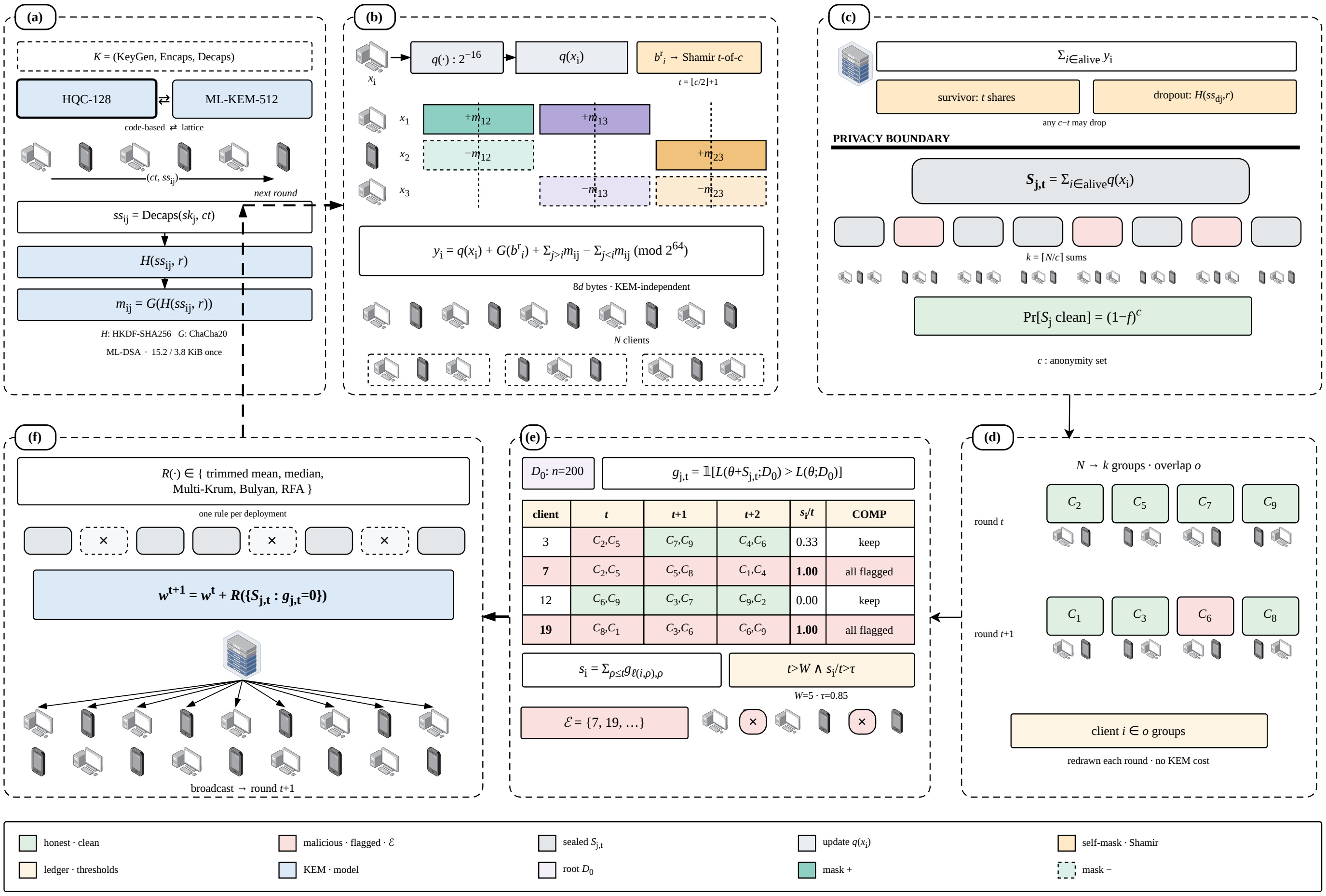

Fig. 1. CB-SAFE, one training round end to end. A one-time code-based (HQC) key setup establishes pairwise secrets reused every round. In the confidentiality layer, clients mask updates so masks cancel within clusters of size c; the server observes only the k cluster sums (anonymity set c), never an individual update. The Byzantine-robustness stage (CB-SAFE+) flags clusters by a loss-probe or, in the trust-free variant, a consensus test; accumulates per-client suspicion across re-randomized rounds; adaptively excludes identified attackers; and robustly aggregates the clean cluster sums into the global model, which is broadcast back.

B. System and Threat Model

A server coordinates N clients running FedAvg over non-IID data partitions. Clients are partitioned into $k = N/c$ fixed clusters of size c. The server is honest-but-curious; a fraction f of clients are malicious and submit poisoned updates; clients may drop out mid-round. Within a cluster, mask recovery uses a t-of-c threshold with $t = \lfloor c/2 \rfloor + 1$, so privacy holds against the server colluding with up to $t-1$ members of a cluster, and any $c-t$ members can drop without stalling the round. Update authentication is out of the code-based scope: HQC cannot sign and no code-based signature is standardized, so where signatures are required we compose the lattice-based ML-DSA [36] and state explicitly that only the confidentiality layer is code-based.

C. KEM-Agnostic Masked Aggregation

Definition 1 (KEM-agnostic cluster masking): Let $\mathcal{K} = (\mathrm{KeyGen}, \mathrm{Encaps}, \mathrm{Decaps})$ be an IND-CCA2 KEM, H a key-derivation function, and G a PRG into $(\mathbb{Z}_{2^{64}})^d$. At setup, each client i publishes pk_i; for each cluster pair $i < j$, client i computes $(ct_{ij}, ss_{ij}) = \mathrm{Encaps}(pk_j)$ and j recovers $ss_{ij} = \mathrm{Decaps}(sk_j, ct_{ij})$. In round r, client i quantizes its update x_i to $q(x_i) \in (\mathbb{Z}_{2^{64}})^d$, draws a self-mask seed b_i^r, Shamir-shares it t-of-c within its cluster, and submits

$$\mathbf{y}_i = q(\mathbf{x}_i) + G(b_i^r) + \sum_{j>i} G\big(H(ss_{ij}, r)\big) - \sum_{j<i} G\big(H(ss_{ij}, r)\big) \pmod{2^{64}}, \tag{1}$$

where the sums run over the cluster peers of i. The server adds each cluster's submissions (pairwise masks cancel), reconstructs each survivor's b_i^r from t shares and removes $G(b_i^r)$; for a dropped client d, each survivor j reveals the per-round seed $H(ss_{dj}, r)$ and the server removes the orphaned mask halves. The server thus obtains exactly $\sum_{i \in \mathrm{alive}} q(x_i)$ per cluster.

Correctness is exact: masking is modular-arithmetic exact, and the only deviation from plain float aggregation is fixed-point quantization (2^{-16} per coordinate). Because encapsulation happens once and per-round seeds come from $H(ss_{ij}, r)$, per-round messages contain no KEM material at all: the masked update is $8d$ bytes regardless of the KEM, and the KEM's key and ciphertext sizes appear only in the one-time setup. Instantiating $\mathcal{K}$ with HQC gives the code-based variant; with ML-KEM [3], the lattice baseline.

Theorem 1 (Privacy against honest-but-curious coalitions): Assume $\mathcal{K}$ is IND-CCA2, H is a secure KDF, and G is

Algorithm 1: Cluster Secure Aggregation (round r)

Input: cluster C of size c, threshold t, per-pair secrets $\{ss_{ij}\}$
Output: cluster sum $\sum_{i\in\text{alive}} q(\mathbf{x}_i)$
foreach *client* $i \in C$ **do**
  $q(\mathbf{x}_i) \leftarrow$ quantize local update
  draw self-mask seed b_i^r; Shamir t-of-c share it to peers
  send masked $\mathbf{y}_i$ by Eq. (1)
$Y \leftarrow \sum_{i\in\text{alive}} \mathbf{y}_i$ `// pairwise masks cancel`
foreach *survivor* i **do**
  reconstruct b_i^r from t shares; $Y \leftarrow Y - G(b_i^r)$
foreach *dropout* d **do**
  survivors reveal $H(ss_{dj}, r)$; remove orphaned mask halves from Y
return Y

a secure PRG. Fix a cluster C of size c with threshold $t = \lfloor c/2 \rfloor + 1$, and let the adversary $\mathcal{A}$ comprise the honest-but-curious server and any statically chosen $T \subset C$ with $|T| \leq t-1$ (the corruption set is fixed before the protocol runs; we do not claim adaptive-corruption security). There exists a PPT simulator that, given only the corrupted clients' inputs and the sum $\sum_{i\in\text{alive}(C)\setminus T} q(x_i)$, produces a view computationally indistinguishable from $\mathcal{A}$'s view of a CB-SAFE round. The CB-SAFE+ flag bits are a deterministic function of the revealed cluster sums and server-local data, so CB-SAFE+ leaks nothing beyond CB-SAFE.

Proof sketch. A hybrid argument. (H1) Replace each pairwise secret ss_{ij} between honest clients by a uniform string: distinguishing H1 from the real game breaks IND-CCA2 of $\mathcal{K}$. (H2) Replace the per-round seeds $H(ss_{ij}, r)$ and mask streams $G(\cdot)$ by uniform: breaks the KDF/PRG. In H2 every honest submission y_i is uniform subject to the alive-honest submissions summing to the revealed cluster sum, which the simulator can sample directly. Shamir shares held by $\leq t-1$ corrupted parties are uniform by perfect secrecy below the threshold, and a dropped client's revealed seeds $H(ss_{dj}, r)$ are independent of other rounds' seeds under the KDF assumption, so both recovery paths are simulatable. Distinct rounds use distinct seeds, so views compose across rounds. □

The anonymity set of an honest client is therefore its cluster's alive honest-member count, and re-randomizing the partition each round (CB-SAFE+) does not change the per-round argument because each round reveals sums of fresh, independently masked updates.

D. Robust Aggregation Across Cluster Sums

The server sees k cluster sums $S_1, \ldots, S_k$ (means after dividing by alive counts) and no individual update. CB-SAFE applies a robust rule across the cluster means: coordinate-wise trimmed mean (trim β per side) or median [14], Multi-Krum [13], Bulyan [19], or the geometric median (RFA) [20]. This resolves the hide-versus-inspect tension structurally (privacy is enforced below the cluster boundary, robustness

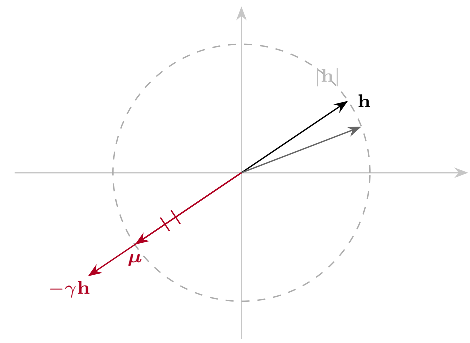

Fig. 2. Laundering geometry (schematic; $-\gamma\mathbf{h}$ drawn with a scale break). Averaging $c-m$ honest updates $\mathbf{h}$ with m amplified sign-flips $-\gamma\mathbf{h}$ yields the cluster mean $\boldsymbol{\mu} = \frac{c-m(1+\gamma)}{c}\mathbf{h}$. At $\gamma^*{=}2c/m-1$ it lands on the $|\mathbf{h}|$ circle: same magnitude as an honest mean, opposite direction, so magnitude- and order-statistic rules cannot see it (Proposition 1).

operates above it) at a quantifiable price. A cluster mean is contaminated if it contains at least one malicious member, so with malicious fraction f and random cluster assignment,

$$\Pr[\text{cluster clean}] = (1-f)^c, \tag{2}$$

and the expected number of clean cluster means is $k(1-f)^c$. Larger c improves privacy (bigger anonymity set) but shrinks the clean fraction the robust rule can rely on; a trimmed mean discarding β per side tolerates at most $\lfloor \beta k \rfloor$ contaminated clusters. c is therefore a tunable privacy–robustness dial, and Section V traces its consequences empirically. Setting $c{=}1$ recovers classical (privacy-free) robust aggregation; setting $c{=}N$ recovers full secure aggregation with no robustness.

The contamination probability, however, understates the problem: cluster averaging also *disguises* what it contaminates.

Proposition 1 (Laundering by cluster averaging): Let each honest update be h (up to noise) and let m members of a cluster of size c submit the scaled sign-flip $-\gamma h$. The cluster mean is $\mu = \frac{c-m(1+\gamma)}{c} h$. Its magnitude equals an honest cluster's ($|\mu| = |h|$) exactly when $\gamma = 2c/m - 1$, while its direction is inverted. At the common attack setting $\gamma{=}5$ with $c{=}3$, $m{=}1$ this holds with equality: the poisoned cluster sum is indistinguishable from honest by any magnitude- or order-statistic test, and a near-symmetric $\pm h$ population drives coordinate-wise trimmed mean and median toward 0, stalling learning entirely.

This laundering effect explains the empirical collapse of every coordinate-wise rule in Section V and motivates direction-based detection: what cluster averaging cannot hide is the *sign* of the update. The proposition idealizes honest updates as a common h; under non-IID heterogeneity real honest updates vary, so it predicts the boundary γ^* in the mean rather than exactly per cluster. We therefore read the four-dataset collapse as strong empirical validation *near* that boundary, not as a guarantee of collapse for arbitrary honest-update distributions.

E. CB-SAFE+: Temporal Group Testing over Cluster Sums

CB-SAFE+ turns the laundering signature into an identification mechanism, using three ingredients. (i) *Re-randomized clustering*: the partition is redrawn every round (pairwise secrets with all peers are established once at setup, so re-clustering adds no per-round KEM cost). (ii) *Loss-probe flags*: the server maintains a small root dataset ($|\mathcal{D}_0|{=}200$ samples held out from all clients, the standard trust-bootstrapping assumption [10], [11]), applies each cluster mean to the current model θ^r, and flags every cluster whose mean *increases* root loss,

$$g_\ell^r = \mathbb{1}\left[\, L(\theta^r + \mathbf{S}_\ell;\, \mathcal{D}_0) > L(\theta^r;\, \mathcal{D}_0) \,\right]. \tag{3}$$

Flags are computed from already-revealed cluster sums and server-local data, so they add no leakage (Theorem 1). The probe is the product of two measured failures. Anchor-free direction flags are sign-ambiguous: the poisoned cluster sums form their own coherent cloud at $-h$, and a Krum-based reference locks onto that cloud in a large fraction of rounds. Anchored *cosine* flags break the symmetry but lose specificity under non-IID data: an $m{=}1$ poisoned cluster mean is dominated by $-\gamma$ times one client's idiosyncratic direction, nearly orthogonal to the balanced anchor, so its sign test approaches a coin flip (at $f{=}0.2$ we measured cosine flags hitting clean clusters as often as dirty ones, and suspicion never separated). The loss probe is immune to this decorrelation because a γ-amplified ascent direction raises root loss regardless of whose data dominates the cluster sum. (iii) *Suspicion accumulation and exclusion*: every member of a flagged cluster gains one suspicion count, so after r rounds client i has accumulated

$$s_i^r = \sum_{\rho=1}^{r} g_{\ell(i,\rho)}^{\rho}, \tag{4}$$

where $\ell(i,\rho)$ is the cluster containing i in round ρ. A malicious client sits in a flagged cluster in essentially every round ($\mathbb{E}[s_i^r/r] \to 1$), while an honest client is flagged only when randomly co-clustered with an attacker, i.e., with probability

$$p_h = 1 - (1-f)^{\,c-1} < 1. \tag{5}$$

A client is excluded once its flagged fraction exceeds a threshold $\tau \in (p_h, 1)$ after a warmup of W rounds,

$$\text{exclude } i \iff r > W \text{ and } s_i^r/r > \tau. \tag{6}$$

By Hoeffding's inequality the two populations separate exponentially: the per-client misclassification probability is at most $e^{-2r(\tau - p_h)^2}$, so a few rounds suffice to isolate the attackers, as the measured suspicion trajectories confirm (Fig. 7). The server thereby identifies individual attackers it has never observed individually: group testing [41], [42] where the pools are the privacy-preserving cluster sums and the tests repeat over training rounds. The *hybrid* variant augments Eq. (4) with a per-round combinatorial (COMP) decode over the overlapping groups (degree o), so a client is suspected only if *all* its groups are flagged, further suppressing false positives.

IV. Implementation

CB-SAFE is implemented in Python on liboqs 0.15.0 (via `liboqs-python`) and PyTorch, with the KEM selected by a one-line configuration change among HQC-128/192/256 and ML-KEM-512/768/1024 (Kyber round-3 parameter sets are retained for comparison with older literature).

Algorithm 2: CB-SAFE+: Temporal Group Testing over Cluster Sums

Input: clients $[N]$, root $\mathcal{D}_0$, cluster size c, threshold τ, warmup W, rounds R
Output: global model θ, excluded set $\mathcal{E}$
$s_i \leftarrow 0\ \forall i;\quad \mathcal{E} \leftarrow \varnothing$
for $r \leftarrow 1$ **to** R **do**
  redraw a random partition of $[N] \setminus \mathcal{E}$ into clusters of size c
  foreach *cluster* ℓ **do**
    $\mathbf{S}_\ell \leftarrow \textsc{ClusterSecureAgg}(\ell, r)/|\text{alive}(\ell)|$ `// Alg. 1`
    $g_\ell^r \leftarrow$ loss-probe flag, Eq. (3)
    foreach *active* $i \in \ell$ *with* $g_\ell^r{=}1$ **do** $s_i \leftarrow s_i + 1$
  if $r > W$ **then**
    foreach *active* i *with* $s_i/r > \tau$ **do** $\mathcal{E} \leftarrow \mathcal{E} \cup \{i\}$
  $\theta \leftarrow \theta + \textsc{RobustAgg}\big(\{\mathbf{S}_\ell : g_\ell^r{=}0\}\big)$
return $\theta,\ \mathcal{E}$

Masks are ChaCha20 keystreams; per-round seeds use HKDF-SHA256; self-mask seeds are shared with Shamir's scheme over $\mathrm{GF}(2^{127}-1)$. *HQC provenance:* liboqs 0.15.0 ships the PQClean constant-time implementation of the Round-4 HQC specification (2023-04-30), the version NIST evaluated and selected [2]; the finalized standard's parameters may differ slightly once published (a draft is expected as FIPS 207). Federated training is simulated in-process; every protocol byte count and crypto timing reported below is measured from real objects on the wire path of the protocol (public keys, ciphertexts, shares, masked vectors), not modeled. *Reproducibility:* Python 3.12, PyTorch 2.5.0 (CUDA 12.4), liboqs-python 0.15.0, on a single NVIDIA RTX 2060 (6 GB); one training round of 30 clients takes ≈21 s. All runs use fixed seed 0 with deterministic partitioning and cluster assignment; CIFAR-10 and FashionMNIST results are averaged over three seeds (Edge-IIoTset over one), significance is by paired t-test with Holm correction, and every experiment is reproducible from a per-run CSV and the released scripts.

V. Evaluation

A. Setup

Task and data. Primary task: CIFAR-10 partitioned across $N{=}30$ clients by a Dirichlet($\alpha{=}0.5$) label-skew split; a CNN with $d{=}291\,498$ parameters; one local epoch per round (SGD, lr 0.01, momentum 0.9, batch 64); $k{=}10$ clusters of $c{=}3$ unless stated. The split is sharply non-IID: clients hold 631 to 3298 samples with strongly skewed label distributions, the heterogeneity under which all robustness results are reported.

Generalization (Section V-F) adds FashionMNIST (same CNN) and Edge-IIoTset (a 15-class tabular IoT intrusion-detection set with a multilayer perceptron), each Dirichlet-partitioned identically. **Configurations.** Plain FedAvg (no cryptography); CB-SAFE/lattice (ML-KEM); CB-SAFE/code-based (HQC), at matched NIST levels. **Attacks.** Label flipping ($y \to 9 - y$), sign flipping (-5Δ), and a backdoor [15]

TABLE II
MEASURED PER-CLIENT OVERHEAD (N=30, c=3, d=291 498). SETUP IS ONE-TIME; PER-ROUND TRAFFIC IS KEM-INDEPENDENT.

KEM	Setup (KiB)	Setup wall (s)	Round (KiB)	Mask (ms)
ML-KEM-512	3.8	0.02	2 277	25
HQC-128	15.2	2.0	2 277	26
ML-KEM-768	5.6	0.02	2 277	27
HQC-192	30.8	5.7	2 277	25
ML-KEM-1024	7.7	0.02	2 277	25
HQC-256	49.4	10.6	2 277	26

(3×3 trigger patch, target class 0, 50% local poison rate) at malicious fractions $f \in \{0.1, 0.2, 0.3\}$, against aggregation rules mean, trimmed mean, median, Multi-Krum, and the CB-SAFE+ reputation defense (Section III-E; server root set of 200 samples held out from all clients). **Metrics.** Test accuracy; backdoor attack success rate (ASR: fraction of triggered non-target test samples classified as the target); communication bytes per client (setup vs. per-round); crypto wall-time; dropout-recovery cost.

B. Overhead: the Code-Based Premium Is a One-Time Cost

Table II reports measured per-client traffic and crypto time. Per-round traffic is identical across all six KEMs (2 277 KiB per client, dominated by the $8d$-byte masked update plus 102 B of Shamir material) because Definition 1 keeps KEM objects out of the per-round path entirely. The KEM appears only in setup: at NIST level 1, HQC costs 15.2 KiB per client against ML-KEM's 3.8 KiB ($4.0\times$; $6.4\times$ at level 5), and 2.0 s of one-time compute for all 30 clients against 0.02 s. Amortized over 40 training rounds ($\sim$89 MiB of per-client update traffic), the code-based premium is below 0.03% of total communication (Table II). A round with 10% dropouts adds only seed-reveal messages (32 B per survivor–dropout pair) and kept server unmasking below 0.28 s in all configurations. The practicality question that motivated this work has a quantitative answer: *cryptographic diversity in FL secure aggregation is essentially free at the protocol level once key establishment is amortized*: the trade-off is a one-time setup constant, not a per-round tax.

C. Scalability in the Client Population

Secure-aggregation cost is set by how many pairwise partners each client must maintain. All-pairs masking [1] gives every client $N-1$ partners, so per-client setup traffic and per-round mask derivation grow as $O(N)$. CB-SAFE masks only *within* clusters of size c, capping partners at $c-1$, so both quantities are *constant in* N. Fig. 3 extrapolates the measured HQC-128 and ML-KEM-512 primitives (Table II) by partner count: at N=1000 a client's one-time setup is 15.2 KiB (HQC) or 3.8 KiB (ML-KEM) regardless of population, versus 7.4 MiB for all-pairs masking, a $500\times$ reduction that widens linearly with N. Because the privacy law $\Pr[S_j \text{ clean}]=(1-f)^c$ and the laundering boundary (Prop. 1) are stated *per cluster*, they are independent of N, and the re-randomized group tests add no per-round KEM cost (Fig. 1d). CB-SAFE therefore targets the cross-device regime where all-pairs masking is infeasible.

Robustness holds as the population scales. Cost is only half the scaling question; the other is whether robustness survives a $16\times$ larger client population. We ran every rule that admits a configuration at N=500 under sign-flip (f=0.2) for 50 rounds (Table III, Fig. 4). FedGT is necessarily absent here: its parity-check matrices and prevalence-estimation tables are hardcoded for $n\leq 31$ [18], so it has no configuration at this population and cannot be run without hand-designing new ones—a concrete scalability ceiling in the method, not a tuning choice. At this scale each client holds only $\sim$100 samples and attacker exclusion consumes the first $\sim$15–20 rounds, so a short 30-round budget truncates every method mid-recovery; extending to 50 rounds lets recovery complete and collapses the between-seed spread (from ±10 to ±2, Fig. 4). At the converged horizon CB-SAFE+ reaches 66.4% (last-five-round mean over three seeds), the coordinate-wise rules remain laundered near chance, and FLTrust's trust weighting, which recovers fastest early, plateaus $\sim$5 points lower (61.3%) because soft down-weighting never fully removes the laundered mass. CB-SAFE+ reaches that accuracy while excluding only $\sim$5 honest clients of 400. Among the methods that admit a configuration at this scale, CB-SAFE+ is the only one that pairs top-tier robustness with near-zero honest exclusion and post-quantum security.

D. Utility and Cryptographic Equivalence

Plain FedAvg reaches 59.0% test accuracy (mean of the final five of 40 rounds; 59.6% at round 40) on the non-IID split. In every round, the same client updates were pushed through the full cryptographic pipeline twice (once under HQC-128, once under ML-KEM-768), and every per-cluster secure sum was compared coordinate-wise against the plain sum. The maximum deviation across all 40 rounds and both KEMs was 2.28×10^{-5}, which *equals* the worst-case fixed-point rounding bound for a 3-element sum ($3\cdot2^{-17} = 2.29\times10^{-5}$): the masking arithmetic itself is exact, so CB-SAFE's accuracy curve is identical to plain FedAvg by construction, not approximately. Both dropout modes were exercised: in round 10, two of three dropped clients landed in the same cluster, driving it below its t=2 threshold: the protocol excluded that cluster and recovered the remaining nine exactly; in round 20, three dropouts in three distinct clusters were all recovered by seed-reveal plus Shamir reconstruction. Measured in-run, setup cost 2.6 s (HQC-128) vs. 0.02 s (ML-KEM-768) for all 30 clients, and steady-state rounds took $\sim$30 ms of client-side masking and $\sim$0.29 s of server-side unmasking, negligible against the $\sim$21 s of local training per round.

E. Robustness Under Attack

The contamination law holds. Across all runs, the realized fraction of clean cluster sums tracked $(1-f)^c$ closely: at c=3, observed $0.70/0.50/0.40$ versus predicted $0.73/0.51/0.34$ for f=0.1/0.2/0.3.

Sign-flip: laundering collapses coordinate-wise rules exactly at the predicted boundary (Table IV, Fig. 6). At f=0.1 ($\approx$3 dirty clusters, within trim capacity) the static rules work: trimmed mean 42.0%, median 43.4%, Multi-Krum

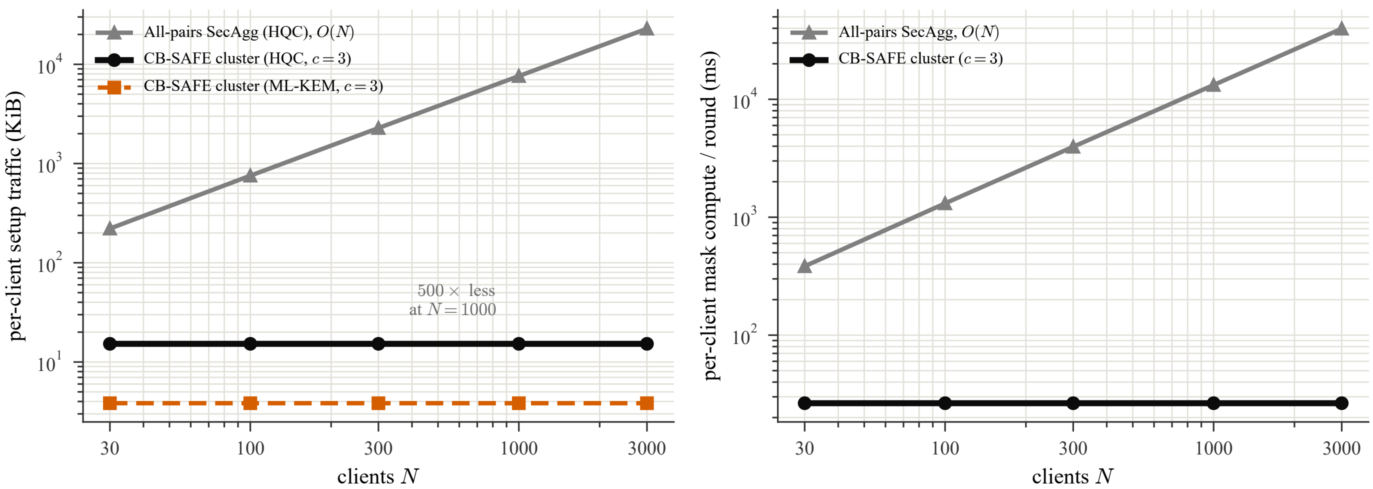

Fig. 3. Per-client cost versus client population N. Because CB-SAFE masks within clusters of size c=3, each client keeps only $c-1$ pairwise partners, so one-time setup traffic (left) and per-round mask compute (right) are constant in N, whereas all-pairs secure aggregation grows as $O(N)$. Curves extrapolate the measured HQC-128 / ML-KEM-512 primitives of Table II by partner count (log–log axes).

TABLE III

SCALING WITH THE CLIENT POPULATION. TEST ACCURACY (%) AT N=100 (30 ROUNDS) AND N=500 (50 ROUNDS) UNDER SIGN-FLIP f=0.2 ON FASHIONMNIST (DIRICHLET α=0.5); PER-SEED VALUES ARE THE MEAN OF THE FINAL FIVE ROUNDS, OVER THREE SEEDS. THE DETECTION BLOCK REPORTS, AT N=500, MALICIOUS CLIENTS CAUGHT OF 100, HONEST CLIENTS WRONGLY EXCLUDED (FP) OF 400, AND THE DERIVED FALSE-ALARM (P_{FA}) AND MISSED-DETECTION (P_{MD}) RATES. BEST VALUE PER COLUMN IN BOLD. AT A CONVERGED HORIZON THE TWO GROUP-TESTING METHODS TIE AT THE TOP; COORDINATE-WISE RULES COLLAPSE; ONLY CB-SAFE+ PAIRS TOP ACCURACY WITH NEAR-ZERO FALSE EXCLUSION. ROUNDS SCALE WITH N BECAUSE ATTACKER EXCLUSION CONSUMES A FIXED NUMBER OF EARLY ROUNDS REGARDLESS OF POPULATION.

	N=100 (30 rd)				N=500 (50 rd)				Detection (N=500)				
Method	s0	s1	s2	mean±sd	s0	s1	s2	mean±sd	Caught	FP↓	P_{FA} ↓	P_{MD} ↓	Id.
CB-SAFE+ (ours)	**76.1**	**75.2**	**73.4**	**74.9±1.4**	**67.8**	**66.9**	**64.5**	**66.4±1.7**	**98/100**	**5**	**0.013**	**0.020**	✓
FLTrust [10]	68.9	65.5	64.2	66.2±2.4	63.0	58.6	62.3	61.3±2.4	–	–	–	–	×
Median	71.8	63.5	68.5	67.9±4.2	29.8	29.1	16.5	25.1±7.5	–	–	–	–	×
Geo-median [20]	73.4	65.4	68.8	69.2±4.0	38.2	30.2	18.5	28.9±9.9	–	–	–	–	×
Multi-Krum	10.0	10.0	40.4	20.1±17.6	10.0	9.9	10.0	10.0±0.1	–	–	–	–	×
Bulyan [19]	10.0	10.0	44.2	21.4±19.8	10.0	12.3	10.0	10.8±1.3	–	–	–	–	×
Trimmed mean	10.0	10.0	10.0	10.0±0.0	10.0	8.4	10.0	9.5±0.9	–	–	–	–	×
Mean	10.0	10.0	10.0	10.0±0.0	10.0	10.0	10.0	10.0±0.0	–	–	–	–	×

TABLE IV

ROBUSTNESS OF AGGREGATION RULES OVER CLUSTER SUMS (c=3, k=10, SEED 0): FINAL TEST ACCURACY UNDER SIGN-FLIP AND ATTACK SUCCESS RATE (ASR, LOWER IS BETTER) UNDER THE BACKDOOR, AT MALICIOUS FRACTION f. BEST PER COLUMN IN BOLD. CB-SAFE+ ADDITIONALLY REPORTS ZERO HONEST FALSE-POSITIVE EXCLUSIONS IN EVERY CONFIGURATION.

	Sign-flip acc. (%)			Backdoor ASR (%)		
Rule	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3
Mean	29.6	10.0	10.0	87.3	94.4	96.7
Trimmed mean	42.0	10.0	10.0	79.7	93.5	96.3
Median	43.4	10.0	10.0	**40.4**	93.3	96.3
Multi-Krum	**52.9**	**42.7**	16.9	86.4	**92.4**	97.2
CB-SAFE+	51.7	37.6	**42.8**	–	94.2	**95.1**

52.9%, versus 29.6% for the undefended mean and 59% clean baseline. At f=0.2 (≈5 dirty clusters) every coordinate-wise rule is pinned at exactly 10.0% (random guessing), not because the model diverges but because the laundered $\pm h$ population drives the aggregate to zero (Proposition 1), while Multi-Krum, which selects whole vectors rather than per-coordinate statistics, still reaches 42.7% (16.9% at f=0.3). Robust rules that rely on magnitude order statistics are structurally weakened by the very mechanism that provides privacy; vector-selection rules retain power.

The full baseline panel confirms the mechanism (Fig. 6, Table VI). Averaged over three seeds, the eight rules separate into three regimes at f=0.3: the coordinate-wise rules (mean, trimmed mean, median) and the robust geometric median RFA [20] are laundered to chance (≈10%), confirming that location- and magnitude-based aggregation fails regardless of sophistication; the vector-selection family degrades but falls (Multi-Krum 20%, Bulyan [19] 31%); and only CB-SAFE+ holds near the clean baseline at 50.0%, whereas FedGT's actual BCJR decoder [18], run per round, collapses to chance (10.0%) at this contamination by over-excluding honest clients (Table V). That RFA collapses while Bulyan merely degrades sharpens Proposition 1: laundering specifically defeats rules

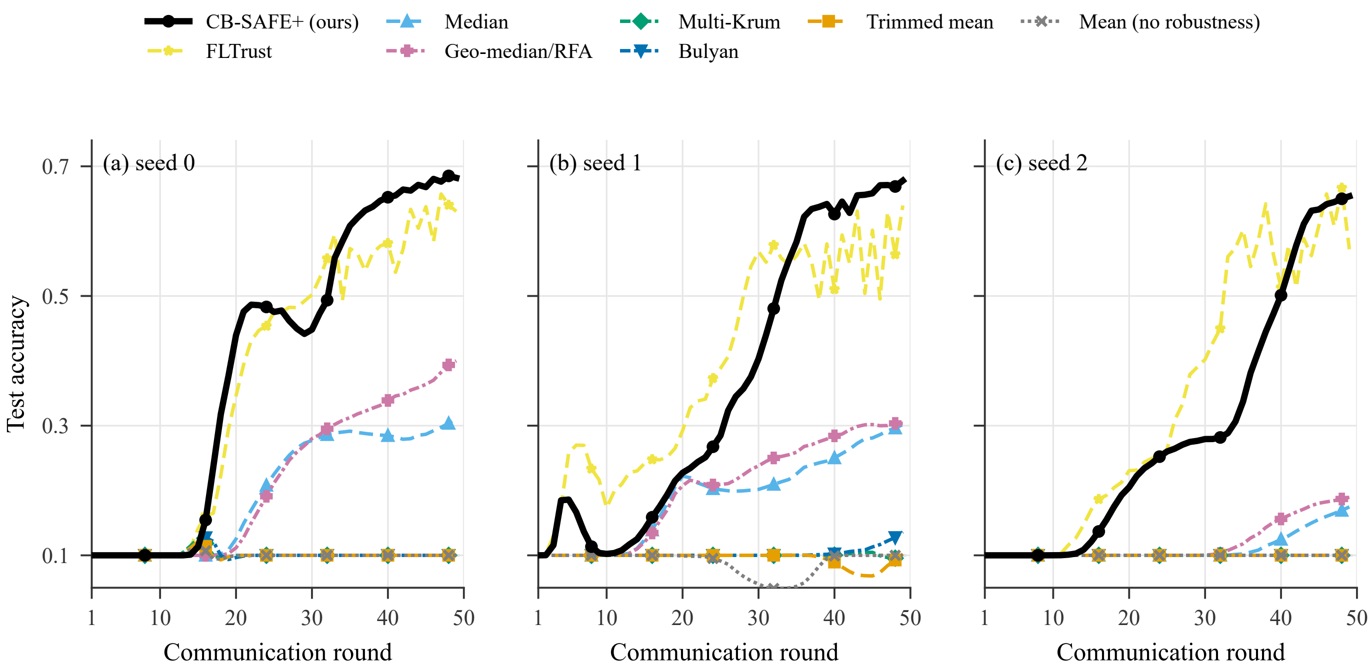

Fig. 4. Test accuracy versus communication round at N=500 (FashionMNIST, sign-flip f=0.2, 50 rounds), one panel per seed (three seeds), all eight aggregation rules that admit a configuration at this scale (FedGT excluded; see text). CB-SAFE+ (heavy black) recovers to ∼66%; the coordinate-wise rules stay laundered near chance (10%); FLTrust leads early but plateaus lower. Recovery begins only after attacker exclusion (∼round 15–20), so a 30-round budget would truncate every curve mid-climb.

TABLE V
ATTACKER IDENTIFICATION ON CIFAR-10 SIGN-FLIP (N=30, MEAN OVER 3 SEEDS): MALICIOUS CLIENTS CAUGHT OUT OF THOSE PRESENT (↑ BETTER) AND HONEST FALSE-POSITIVE EXCLUSIONS (↓ BETTER; 24/24/21 HONEST CLIENTS AT f=.1/.2/.3). FEDGT IS ITS ACTUAL BCJR GROUP-TESTING DECODER [18], RUN PER ROUND. CB-SAFE+ CATCHES EVERY ATTACKER WITH NEAR-ZERO FALSE POSITIVES, WHEREAS FEDGT BOTH MISSES ATTACKERS AND WRONGLY EXCLUDES 13–16 HONEST CLIENTS.

	f=0.1		f=0.2		f=0.3	
Method	caught↑	FP↓	caught↑	FP↓	caught↑	FP↓
FedGT [18]	2.7/3	13.0	5.7/6	14.7	7.7/9	15.7
CB-SAFE+ (ov1)	3/3	0.3	3/6	0.7	4/9	1.3
CB-SAFE+ hybrid	**3/3**	**0.0**	**6/6**	**0.7**	**9/9**	**0.3**

that trust the *aggregate* direction or magnitude, precisely what cluster averaging preserves for the attacker, whereas whole-vector selection resists longer.

CB-SAFE+ restores learning past the static breakdown (Table IV). With loss-probe flags and temporal suspicion, the defense identified all 3 of 3 attackers at f=0.1 (51.7%, near the clean ceiling) and 8 of 9 sign-flip attackers with *zero* honest false positives at f=0.3, recovering to 42.8% accuracy where every static coordinate-wise rule sat at 10% and Multi-Krum at 16.9%, comparable to the 39–41% the median achieves *without any privacy* (c=1), i.e., the defense refunds the privacy dial's cost in rounds rather than anonymity. At f=0.2 per-round flag filtering alone recovers 37.6% (exclusions are rare because m=1 laundered sums raise root loss only mildly); Multi-Krum's 44% remains stronger in this moderate regime, so the defense's advantage grows with attack severity and the two are complementary rather than ranked. Under label flipping (a weak attack in this regime: all rules land within 44–52%) the probe flags only the worst clusters and excludes conservatively (zero false positives at f=0.2), matching the best static rule.

Backdoor: a mechanism-independent blind spot. The trigger attack leaves main-task accuracy intact for every rule (50–55%) while ASR stays at 86–97% across mean, trimmed mean, Multi-Krum, *and* CB-SAFE+ (Fig. 5): backdoored cluster sums *reduce* clean root loss and align with the honest direction, so they are invisible to loss- and direction-based tests alike. The one partial exception is the coordinate-wise median at f=0.1, which suppresses ASR to 40%: order statistics can filter the trigger direction's coordinates when contamination is sparse. We therefore claim CB-SAFE+ for *untargeted* model poisoning only; targeted trigger attacks under secure aggregation remain open, consistent with their difficulty even without privacy constraints.

F. Generalization Across Datasets and Modalities

To test whether the laundering effect and CB-SAFE+'s recovery are artifacts of one dataset, we repeat the sign-flip evaluation on FashionMNIST (a second image benchmark, three seeds) and on Edge-IIoTset (tabular IoT/IIoT intrusion detection with a multilayer perceptron, a different modality in the security domain of the closest prior work [7]). The pattern is identical everywhere (Table VI, Fig. 6): every coordinate-wise rule collapses to chance at $f \geq 0.2$ (10.0% on the 10-class image sets, 7.3% on 15-class Edge-IIoTset), Multi-Krum degrades gracefully then falls at f=0.3, and CB-SAFE+ tracks the clean baseline. The round-by-round view

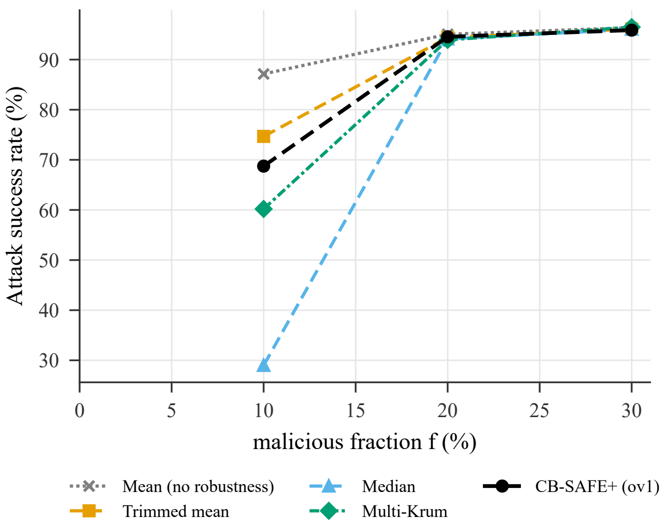

Fig. 5. Backdoor attack success rate vs. malicious fraction. No sum-level rule suppresses the trigger (median at f=0.1 partially excepted): backdoored sums help the main task and evade loss/direction probes, the honest scope limit of robustness under secure aggregation.

(Fig. 6) shows this is not an endpoint artifact: the static rules decay progressively while CB-SAFE+ dips during warmup and recovers as exclusions fire. At f=0.3 CB-SAFE+ retains 84%, high-80s, and 97% of the no-attack accuracy on CIFAR-10, FashionMNIST, and Edge-IIoTset respectively, versus 12–18% for the worst static rule. Pooling all matched (dataset, f, seed) cells, CB-SAFE+ beats every baseline under a paired t-test with Holm correction: versus the mean by 48.3 points ($p<10^{-4}$), the median by 37.7 ($p=3\times10^{-4}$), Multi-Krum by 11.9 ($p=9\times10^{-3}$), and FedGT's actual BCJR decoder—over the three datasets where FedGT admits a configuration—by 23.1 ($p=5\times10^{-4}$). The Edge-IIoTset result is the sharpest: at f=0.3 CB-SAFE+ holds 61.5% against a 63.7% clean baseline while mean, trimmed mean, and median all sit at 7.3%.

G. Secondary Attack: Label Flipping

Label flipping is a far milder attack than sign-flip, and it doubles as a control. Table VII shows that *no* coordinate-wise rule collapses: the undefended mean retains 47–63% at f=0.3, versus 10% under sign-flip. That contrast isolates the laundering mechanism (Proposition 1) as the cause of the sign-flip failures, rather than any generic fragility of the setup. CB-SAFE+ stays at or above every baseline, and on FashionMNIST it holds 86% at f=0.3 where the mean falls to 63%.

H. Ablation: Which Component Earns the Robustness

CB-SAFE+ layers three ingredients on top of clustered secure aggregation: temporal reputation, overlapping re-randomized groups, and a per-round COMP decode. Table VIII isolates each under the identical sign-flip protocol. The base temporal reputation (ov1) already restores learning at moderate contamination but degrades at f=0.3 (37.9% on CIFAR-10); adding overlapping groups (ov4) lifts it to 48.8%, and the full hybrid COMP decode reaches 50.0%— far above FedGT's actual BCJR decoder, which collapses to chance at this contamination (Table V). Each component contributes, and the gains concentrate in the high-f regime where laundering is strongest. The trust-free variant, which uses *no* root dataset, matches the others at f=0.1 but collapses beyond it: attacker identification without any trusted anchor is possible only in the low-contamination regime, a capability boundary we state rather than hide.

I. The Privacy–Robustness Dial, Measured

Fixing the rule (median) and sweeping cluster size traces the dial empirically (Table IXa, Fig. 8). Without privacy (c=1), the median degrades gently from 50% to 39% as f grows to 0.3, i.e., classical robust aggregation. At c=3 the same rule holds to f=0.1 (43.4%) and collapses beyond; at c=5 degradation begins already at f=0.1 (33.7%): the breakdown frontier shifts left exactly as $(1-f)^c$ predicts (Fig. 8). Two further observations sharpen the picture. First, at f=0.05 privacy is *free*: c=3 and c=5 match or slightly exceed c=1 (52.2% vs. 50.2%), because cluster averaging denoises before the median. Second, the dial's cost is refundable: at c=3, f=0.3, where the private median collapses to 10% against 39–41% without privacy, CB-SAFE+ recovers comparable accuracy *while keeping the anonymity set*, by paying in rounds (warmup) rather than in privacy.

VI. Security Discussion and Limitations

What the design guarantees. Within a cluster, privacy reduces to the double-masking argument of [1] with the DH-style key agreement replaced by an IND-CCA2 KEM: masks are ChaCha20 outputs keyed by HKDF of encapsulated secrets, so an honest-but-curious server colluding with fewer than t cluster members learns only cluster sums. The robust layer never inspects anything finer than a cluster mean. **What it does not.** We do not claim security against an actively malicious server (who could misreport dropouts; standard mitigations apply), nor differential privacy on the cluster sums themselves; the anonymity set is bounded by the alive cluster size, and cluster sums of very small clusters leak more than full-cohort sums. Robustness degrades predictably as $k(1-f)^c$ approaches the trim capacity: at c=3, f=0.3 leaves an expected 3.4 clean clusters of 10, near the breakdown of a 2-per-side trimmed mean; this is the price of the anonymity set and we report it rather than hide it. HQC operations are ∼200× slower than ML-KEM's, which is immaterial here (setup-only) but would matter for protocols that encapsulate per round.

VII. Conclusion

CB-SAFE positions cryptographic diversity as a configuration choice rather than a research programme: the KEM sits behind one interface, and the measured cost of choosing the code-based occupant is a one-time setup constant. The more consequential finding is what secure aggregation does to robustness: cluster averaging does not merely dilute poisoning, it *launders* it, transforming conspicuous attacks into plausible-looking sums that defeat exactly the rules practitioners would

TABLE VI

TEST ACCURACY (%) UNDER THE SIGN-FLIP (LAUNDERING) ATTACK ACROSS FOUR DATASETS AND MALICIOUS FRACTIONS f (MEAN $\pm$ STD OVER 3 SEEDS FOR CIFAR-10/FASHIONMNIST/EDGE-IIOTSET, AND FOR CB-SAFE+ AND FEDGT ON EMNIST; OTHER EMNIST BASELINES ARE SINGLE SEED). FEDGT IS ITS ACTUAL BCJR GROUP-TESTING DECODER [18], RUN PER ROUND; IT IS NOT EVALUATED ON EDGE-IIOTSET (DASH). HIGHER IS BETTER; BEST PER COLUMN IN BOLD. A DASH (—) MARKS A CONFIGURATION NOT EVALUATED. CB-SAFE+ VARIANTS ARE ABLATED IN TABLE VIII.

	CIFAR-10			FashionMNIST			EMNIST			Edge-IIoTset		
Method	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3
FedAvg (mean)	21.4 ±8.3	10.0 ±0.0	10.0 ±0.0	48.9 ±28.5	10.0 ±0.0	10.0 ±0.0	35.9	2.1	2.1	43.0 ±12.1	7.4 ±0.2	7.4 ±0.2
Trimmed mean	45.4 ±2.4	10.0 ±0.0	10.0 ±0.0	82.7 ±1.4	10.0 ±0.0	10.0 ±0.0	81.7	2.1	2.1	60.2 ±1.6	8.1 ±0.8	7.4 ±0.2
Median	47.8 ±3.2	10.0 ±0.0	10.0 ±0.0	83.6 ±1.1	10.0 ±0.0	10.0 ±0.0	83.4	2.1	2.1	60.7 ±0.8	13.8 ±5.1	7.4 ±0.2
Multi-Krum	53.6 ±0.8	39.8 ±2.2	20.3 ±10.1	85.9 ±0.8	83.0 ±1.6	43.1 ±23.9	85.0	79.0	2.1	63.2 ±0.5	57.6 ±2.8	32.7 ±18.6
Bulyan	53.3 ±0.3	**49.8 ±0.9**	30.8 ±16.3	85.1 ±0.6	83.6 ±1.1	55.8 ±32.5	84.9	83.5	2.1	62.3 ±0.9	60.8 ±0.5	26.1 ±25.6
Geo-median / RFA	49.7 ±2.2	38.8 ±1.7	16.7 ±9.5	83.9 ±1.1	74.0 ±4.3	27.0 ±24.1	83.5	74.2	2.1	61.5 ±1.1	53.2 ±9.2	20.9 ±18.9
FLTrust	23.8 ±7.7	26.1 ±4.4	22.0 ±7.1	75.0 ±0.3	75.0 ±0.8	73.1 ±0.4	50.9	48.9	48.1	42.0 ±1.3	35.1 ±10.1	28.9 ±0.5
FedGT [18]	48.1 ±7.2	43.1 ±5.1	10.0 ±0.0	85.6 ±0.9	73.2 ±15.5	31.3 ±36.9	83.5 ±3.1	81.8 ±2.2	2.1 ±0.0	–	–	–
CB-SAFE+ (ours)	**53.9 ±0.5**	49.5 ±3.4	**50.0 ±2.2**	**86.0 ±0.4**	**86.2 ±0.4**	**85.1 ±0.8**	**85.7 ±0.2**	**85.4 ±0.1**	**85.4 ±0.2**	**63.8 ±0.6**	**63.0 ±0.4**	**62.7 ±0.9**

TABLE VII

TEST ACCURACY (%) UNDER THE LABEL-FLIP ATTACK ACROSS FOUR DATASETS AND MALICIOUS FRACTIONS f (SINGLE SEED, EXCEPT CB-SAFE+ AND FEDGT ON EMNIST, WHICH ARE MEAN $\pm$ STD OVER 3 SEEDS). LABEL FLIPPING IS A MILD ATTACK: UNLIKE SIGN-FLIP (TABLE VI), COORDINATE-WISE RULES DO *not* COLLAPSE, WHICH ISOLATES LAUNDERING AS THE MECHANISM BEHIND THE SIGN-FLIP FAILURES. HIGHER IS BETTER; BEST PER COLUMN IN BOLD. A DASH (—) MARKS A CONFIGURATION NOT EVALUATED.

	CIFAR-10			FashionMNIST			EMNIST			Edge-IIoTset		
Method	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3
FedAvg (mean)	**53.9**	51.9	47.4	85.4	78.4	62.6	84.9	82.9	77.0	**62.7**	**63.5**	60.8
Trimmed mean	52.7	51.1	47.3	85.6	78.7	77.0	85.4	83.5	80.0	62.5	62.7	60.5
Median	52.0	51.2	44.8	85.5	84.7	75.2	85.6	83.6	78.2	61.5	62.7	59.7
Multi-Krum	50.5	50.4	43.6	85.6	86.2	83.2	85.5	84.2	82.0	62.4	62.2	60.8
Bulyan	50.9	49.0	43.7	85.2	85.5	81.9	85.2	84.2	81.5	61.2	61.6	60.5
Geo-median / RFA	53.6	52.1	46.1	85.6	85.6	69.8	85.6	83.5	79.8	62.2	63.4	61.6
FLTrust	25.7	26.3	25.0	75.4	75.3	73.0	50.0	48.2	44.8	37.4	38.2	37.1
FedGT [TIFS'25]	53.8	52.8	**51.7**	86.0	86.3	86.1	**85.7 ±0.3**	85.3 ±0.3	84.9 ±0.3	62.0	62.7	62.0
CB-SAFE+ (ours)	53.6	**53.2**	51.1	**86.4**	**86.5**	**86.2**	85.7 ±0.2	**85.4 ±0.2**	**85.4 ±0.1**	62.4	62.5	**62.4**

TABLE VIII

ABLATION OF CB-SAFE+ COMPONENTS UNDER SIGN-FLIP (SAME PROTOCOL AS TABLE VI). OVERLAPPING GROUPS AND THE HYBRID COMP DECODE EACH ADD ROBUSTNESS AT HIGH f; THE TRUST-FREE VARIANT USES NO ROOT DATASET BUT DEGRADES BEYOND f=0.1. BEST PER COLUMN IN BOLD.

	CIFAR-10			FashionMNIST			EMNIST			Edge-IIoTset		
Method	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3	f=.1	f=.2	f=.3
Base: temporal reputation (ov1)	53.0 ±0.6	47.1 ±2.6	37.9 ±12.6	85.7 ±0.5	86.0 ±0.5	83.1 ±1.9	85.4	84.8	85.0	62.6 ±0.5	62.5 ±0.6	62.1 ±0
+ overlapping groups (ov4)	53.5 ±0.6	49.3 ±3.0	48.8 ±2.0	**86.1 ±0.4**	**86.2 ±0.4**	84.8 ±1.1	**85.9**	**85.6**	**85.5**	63.7 ±0.6	62.9 ±0.6	**62.7** ±0
+ hybrid COMP decode (full)	53.9 ±0.5	**49.5 ±3.4**	**50.0 ±2.2**	86.0 ±0.4	86.2 ±0.4	**85.1 ±0.8**	85.7 ±0.2	85.4 ±0.1	85.4 ±0.2	**63.8 ±0.6**	**63.0 ±0.4**	62.7 ±0
Trust-free (no root data)	**54.0 ±0.1**	10.0 ±0.0	10.0 ±0.0	85.9 ±0.4	10.0 ±0.0	10.0 ±0.0	85.8	2.1	2.1	63.1 ±0.6	25.4 ±25.2	7.4 ±0.

reach for. Defending therefore requires signals that survive aggregation (direction, loss) accumulated over time. CB-SAFE+ shows one such design that identifies individual attackers from group observations without spending any privacy. The open questions our results make concrete: targeted backdoors remain invisible to sum-level probes at every malicious fraction we tested, an actively malicious server is outside our threat model, and the temporal identification argument should extend to an adaptive attacker who modulates its poisoning to stay below the probe margin; quantifying that game is the natural next step. Multi-seed replication and a second dataset are in progress; the implementation and all measurement scripts are released open-source as, to our knowledge, the first code-based reference point for post-quantum secure aggregation in FL.

APPENDIX A
DATASET DETAILS AND MODELS

All datasets are partitioned across N=30 clients by a Dirichlet(α=0.5) label-skew split [47]; each client runs one local epoch of SGD per round. **CIFAR-10** [43]: 50,000 training / 10,000 test images, 10 classes; a convolutional network with d=291,498 parameters (lr 0.01, momentum 0.9, batch 64). **FashionMNIST** [44]: 60,000/10,000 grayscale images, 10 classes, same network adapted to one input channel. **EMNIST-balanced** [45]: 112,800/18,800 handwritten characters, 47 classes, a harder label space; same convolutional backbone. **Edge-IIoTset** [46]: a tabular IoT/IIoT intrusion-detection corpus with 15 classes, class-stratified subsampling to at most 120,000 rows, leakage/identifier columns dropped, features standardized, classified by a multilayer perceptron.

TABLE IX
ABLATIONS ON CIFAR-10 SIGN-FLIP (FINAL ACCURACY, %). (A) THE CLUSTER-SIZE DIAL: LARGER c ENLARGES THE ANONYMITY SET BUT SHIFTS THE MEDIAN'S BREAKDOWN FRONTIER LEFT, EXACTLY AS $(1-f)^c$ (EQ. (2)) PREDICTS. (B) OVERLAPPING RE-RANDOMIZED CLUSTERS (DEGREE o) EXTEND CB-SAFE+ RECOVERY TO HIGHER f.

(a) cluster size c (rule: median)

	f=.05	f=.1	f=.2	f=.3
c=1 (no privacy)	51	49	45	40
c=3	53	49	10	10
c=5	52	40	10	10

(b) overlap degree o (rule: CB-SAFE+ reputation)

	f=.1	f=.2	f=.3
o=1	54	48	39
o=4	54	51	49

Image datasets use 30 rounds; Edge-IIoTset uses 25.

APPENDIX B
ATTACK CONFIGURATIONS

All attacks are offline (training-time) data/model poisoning at malicious fractions $f \in \{0.1, 0.2, 0.3\}$. **Sign-flip:** each malicious client submits $-\gamma$ times its honest update with amplification γ=5, the setting at which laundering is exact for c=3, m=1 (Proposition 1). **Label-flip:** labels are deterministically remapped ($y \to 9-y$ on the 10-class image sets), a comparatively weak attack in this regime. **Backdoor:** a 3×3 trigger patch with target class 0 and a 50% local poison rate [15], evaluated by attack success rate (ASR).

APPENDIX C
EXTENDED HYPERPARAMETERS AND REPRODUCIBILITY

Unless stated: cluster size c=3 (k=10 clusters), Shamir threshold $t=\lfloor c/2 \rfloor+1=2$, robust rule trimmed mean/median with trim β per side, overlap degree $o \in \{1, 4\}$, server root $|\mathcal{D}_0|$=200 held out from all clients, exclusion threshold τ=0.85 (or the adaptive gap rule) after a warmup of W=5 rounds. KEMs span HQC-128/192/256 and ML-KEM-512/768/1024 at matched NIST levels; masks are ChaCha20 keystreams with HKDF-SHA256 per-round seeds. Runs use Python 3.12, PyTorch 2.5.0 (CUDA 12.4), liboqs-python 0.15.0 on a single NVIDIA RTX 2060 (6 GB). CIFAR-10, FashionMNIST, and Edge-IIoTset results are averaged over three seeds and EMNIST over one; significance is assessed by a paired t-test with Holm correction. Every run emits a per-round CSV and is reproducible from the released scripts.

REFERENCES

[1] K. Bonawitz *et al.*, "Practical secure aggregation for privacy-preserving machine learning," in *Proc. ACM CCS*, 2017, pp. 1175–1191.
[2] National Institute of Standards and Technology, "Status report on the fourth round of the NIST post-quantum cryptography standardization process," NIST IR 8545, Mar. 2025.
[3] National Institute of Standards and Technology, "Module-lattice-based key-encapsulation mechanism standard," FIPS 203, Aug. 2024.
[4] X. Zhang, H. Deng, R. Wu, J. Ren, and Y. Ren, "PQSF: Post-quantum secure privacy-preserving federated learning," *Sci. Rep.*, vol. 14, Art. no. 23553, 2024.
[5] X. Qin and R. Xu, "Efficient post-quantum cross-silo federated learning based on key homomorphic pseudo-random function," *Mathematics*, vol. 13, no. 9, Art. no. 1404, 2025.
[6] P. Narsimhulu, P. Chithaluru, and R. Aluvalu, "Efficient post-quantum cryptographic signature aggregation for low-latency distributed networks," *EURASIP J. Inf. Secur.*, vol. 2026, Art. no. 6, 2026.
[7] "Byzantine-robust federated learning framework with post-quantum secure aggregation for real-time threat intelligence sharing in critical IoT infrastructure," arXiv:2601.01053, 2026.
[8] "CQSA: Byzantine-robust clustered quantum secure aggregation in federated learning," arXiv:2602.22269, 2026.
[9] J. Singh, P. Singh, A. Kaur, and M. Hedabou, "Post-quantum secure fog-edge computing using federated learning with blockchain," *J. Supercomput.*, vol. 81, Art. no. 1249, 2025.
[10] X. Cao, M. Fang, J. Liu, and N. Z. Gong, "FLTrust: Byzantine-robust federated learning via trust bootstrapping," in *Proc. NDSS*, 2021.
[11] C. Xie, S. Koyejo, and I. Gupta, "Zeno: Distributed stochastic gradient descent with suspicion-based fault-tolerance," in *Proc. ICML*, 2019.
[12] J. H. Bell, K. A. Bonawitz, A. Gascón, T. Lepoint, and M. Raykova, "Secure single-server aggregation with (poly)logarithmic overhead," in *Proc. ACM CCS*, 2020, pp. 1253–1269.
[13] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, "Machine learning with adversaries: Byzantine tolerant gradient descent," in *Proc. NeurIPS*, 2017, pp. 119–129.
[14] D. Yin, Y. Chen, R. Kannan, and P. Bartlett, "Byzantine-robust distributed learning: Towards optimal statistical rates," in *Proc. ICML*, 2018, pp. 5650–5659.
[15] E. Bagdasaryan, A. Veit, Y. Hua, D. Estrin, and V. Shmatikov, "How to backdoor federated learning," in *Proc. AISTATS*, 2020, pp. 2938–2948.
[16] J. So, B. Güler, and A. S. Avestimehr, "Byzantine-resilient secure federated learning," *IEEE J. Sel. Areas Commun.*, vol. 39, no. 7, pp. 2168–2181, 2021.
[17] H. Nguyen, S. Huda, Y. Nogami, and T. T. Nguyen, "Security in post-quantum era: A comprehensive survey on lattice-based algorithms," *IEEE Access*, vol. 13, pp. 89003–89024, 2025.
[18] M. Xhemrishi, J. Östman, A. Wachter-Zeh, and A. Graell i Amat, "FedGT: Identification of malicious clients in federated learning with secure aggregation," *IEEE Trans. Inf. Forensics Security*, vol. 20, pp. 2577–2592, 2025.
[19] E. M. El Mhamdi, R. Guerraoui, and S. Rouault, "The hidden vulnerability of distributed learning in Byzantium," in *Proc. ICML*, 2018, pp. 3521–3530.
[20] K. Pillutla, S. M. Kakade, and Z. Harchaoui, "Robust aggregation for federated learning," *IEEE Trans. Signal Process.*, vol. 70, pp. 1142–1154, 2022.
[21] M. Fang, X. Cao, J. Jia, and N. Z. Gong, "Local model poisoning attacks to Byzantine-robust federated learning," in *Proc. USENIX Security*, 2020, pp. 1605–1622.
[22] V. Shejwalkar and A. Houmansadr, "Manipulating the Byzantine: Optimizing model poisoning attacks and defenses for federated learning," in *Proc. NDSS*, 2021.
[23] T. D. Nguyen *et al.*, "FLAME: Taming backdoors in federated learning," in *Proc. USENIX Security*, 2022, pp. 1415–1432.
[24] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proc. AISTATS*, 2017, pp. 1273–1282.
[25] P. Kairouz *et al.*, "Advances and open problems in federated learning," *Found. Trends Mach. Learn.*, vol. 14, no. 1–2, pp. 1–210, 2021.
[26] L. Zhu, Z. Liu, and S. Han, "Deep leakage from gradients," in *Proc. NeurIPS*, 2019, pp. 14747–14756.
[27] J. Geiping, H. Bauermeister, H. Dröge, and M. Moeller, "Inverting gradients: How easy is it to break privacy in federated learning?," in *Proc. NeurIPS*, 2020, pp. 16937–16947.
[28] M. Fredrikson, S. Jha, and T. Ristenpart, "Model inversion attacks that exploit confidence information and basic countermeasures," in *Proc. ACM CCS*, 2015, pp. 1322–1333.
[29] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *Proc. IEEE Symp. Secur. Privacy*, 2017, pp. 3–18.
[30] A. R. Elkordy, J. Zhang, Y. H. Ezzeldin, K. Psounis, and S. Avestimehr, "How much privacy does federated learning with secure aggregation guarantee?," *Proc. Privacy Enhancing Technol.*, 2022, pp. 510–526.
[31] J. So *et al.*, "LightSecAgg: A lightweight and versatile design for secure aggregation in federated learning," in *Proc. MLSys*, 2022, pp. 694–720.
[32] T. Jahani-Nezhad, M. A. Maddah-Ali, S. Li, and G. Caire, "SwiftAgg: Communication-efficient and dropout-resistant secure aggregation for

federated learning with worst-case security guarantees," in *Proc. IEEE ISIT*, 2022, pp. 103–108.

[33] P. W. Shor, "Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer," *SIAM J. Comput.*, vol. 26, no. 5, pp. 1484–1509, 1997.

[34] R. J. McEliece, "A public-key cryptosystem based on algebraic coding theory," *JPL Deep Space Netw. Prog. Rep.*, pp. 114–116, 1978.

[35] F. J. MacWilliams and N. J. A. Sloane, *The Theory of Error-Correcting Codes*. Amsterdam, The Netherlands: North-Holland, 1977.

[36] National Institute of Standards and Technology, "Module-lattice-based digital signature standard," FIPS 204, Aug. 2024.

[37] G. Baruch, M. Baruch, and Y. Goldberg, "A little is enough: Circumventing defenses for distributed learning," in *Proc. NeurIPS*, 2019, pp. 8635–8645.

[38] H. Wang *et al.*, "Attack of the tails: Yes, you really can backdoor federated learning," in *Proc. NeurIPS*, 2020, pp. 16070–16084.

[39] V. Tolpegin, S. Truex, M. E. Gursoy, and L. Liu, "Data poisoning attacks against federated learning systems," in *Proc. ESORICS*, 2020, pp. 480–501.

[40] Z. Zhang, X. Cao, J. Jia, and N. Z. Gong, "FLDetector: Defending federated learning against model poisoning attacks via detecting malicious clients," in *Proc. ACM KDD*, 2022, pp. 2545–2555.

[41] R. Dorfman, "The detection of defective members of large populations," *Ann. Math. Stat.*, vol. 14, no. 4, pp. 436–440, 1943.

[42] M. Aldridge, O. Johnson, and J. Scarlett, "Group testing: An information theory perspective," *Found. Trends Commun. Inf. Theory*, vol. 15, no. 3–4, pp. 196–392, 2019.

[43] A. Krizhevsky, "Learning multiple layers of features from tiny images," Univ. Toronto, Tech. Rep., 2009.

[44] H. Xiao, K. Rasul, and R. Vollgraf, "Fashion-MNIST: A novel image dataset for benchmarking machine learning algorithms," arXiv:1708.07747, 2017.

[45] G. Cohen, S. Afshar, J. Tapson, and A. van Schaik, "EMNIST: Extending MNIST to handwritten letters," in *Proc. IJCNN*, 2017, pp. 2921–2926.

[46] M. A. Ferrag, O. Friha, D. Hamouda, L. Maglaras, and H. Janicke, "Edge-IIoTset: A new comprehensive realistic cyber security dataset of IoT and IIoT applications for centralized and federated learning," *IEEE Access*, vol. 10, pp. 40281–40306, 2022.

[47] T.-M. H. Hsu, H. Qi, and M. Brown, "Measuring the effects of non-identical data distribution for federated visual classification," arXiv:1909.06335, 2019.

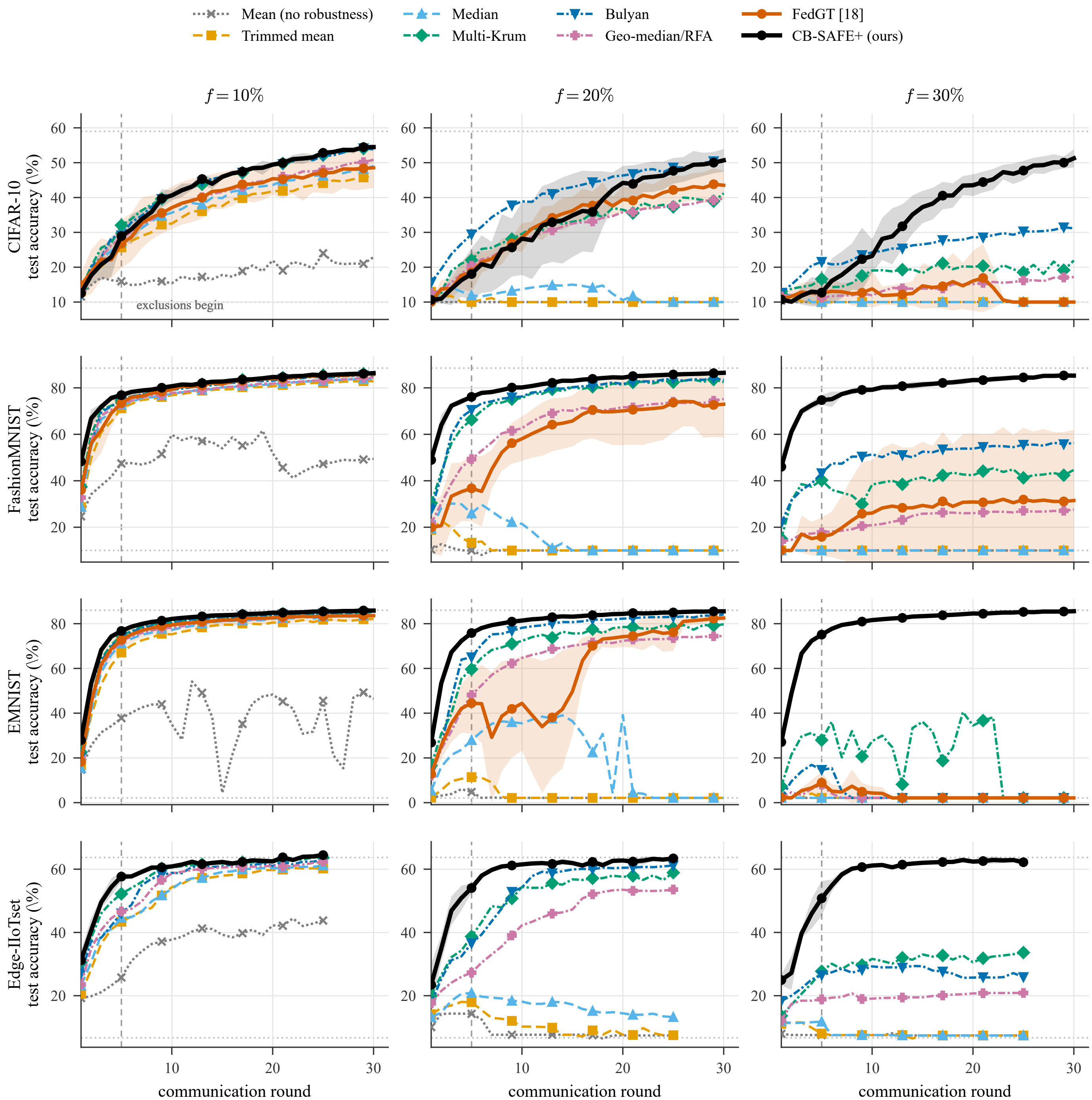

Fig. 6. Training dynamics under the sign-flip attack: test accuracy versus communication round for eight aggregation rules, across four datasets (rows) and malicious fractions f (columns). FedGT is its actual BCJR decoder [18], which has no configuration for Edge-IIoTset and is therefore omitted from that row. Curves are the mean over 3 seeds (single seed for the EMNIST baselines); shaded bands are ± 1 SD for CB-SAFE+ and FedGT. The dashed vertical marks the warmup $W=5$ after which exclusions begin; dotted lines mark chance and the no-attack baseline. Coordinate-wise rules and the geometric median decay progressively to chance at $f \geq 0.2$; CB-SAFE+ dips during warmup and then recovers and holds, whereas FedGT degrades and collapses toward chance at $f=0.3$ by over-excluding honest clients. Final accuracies for all datasets and fractions are in Table VI.

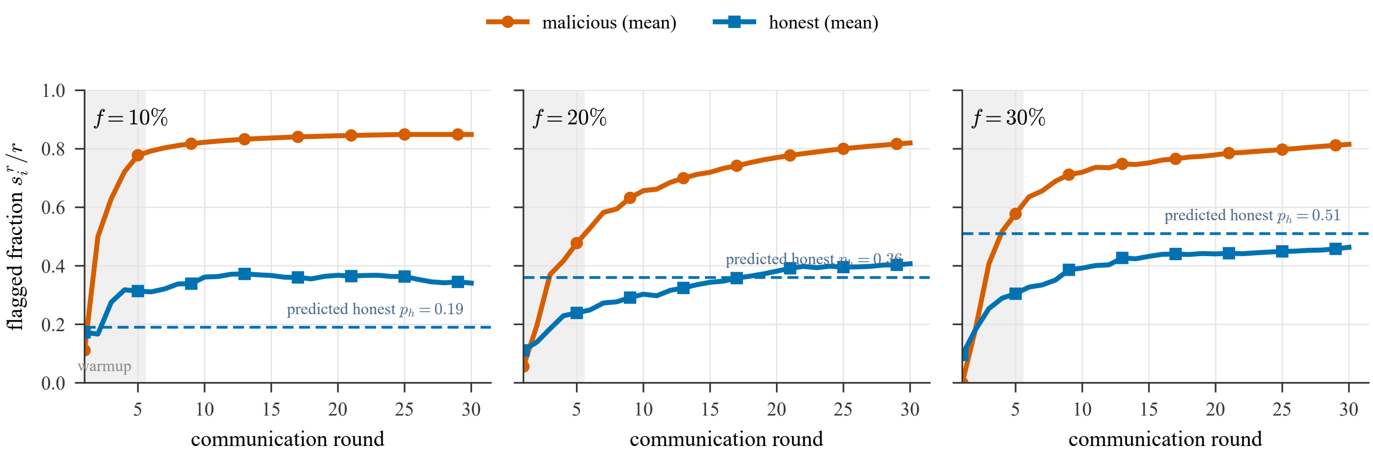

Fig. 7. Temporal suspicion separation (CB-SAFE+ on CIFAR-10): population-mean flagged fraction s_i^r/r of malicious versus honest clients over rounds, for each malicious fraction f (mean over 3 seeds). The two populations separate within a few rounds, so attackers are identified from group-level observations alone (Eqs. (4)–(6)). The dashed line is the predicted honest co-clustering rate $p_h = 1 - (1 - f)^{c-1}$ (Eq. (5)); the loss probe adds a few honest flags at low f. Exclusion uses an adaptive gap between the two populations rather than a fixed threshold; the warmup window is shaded.

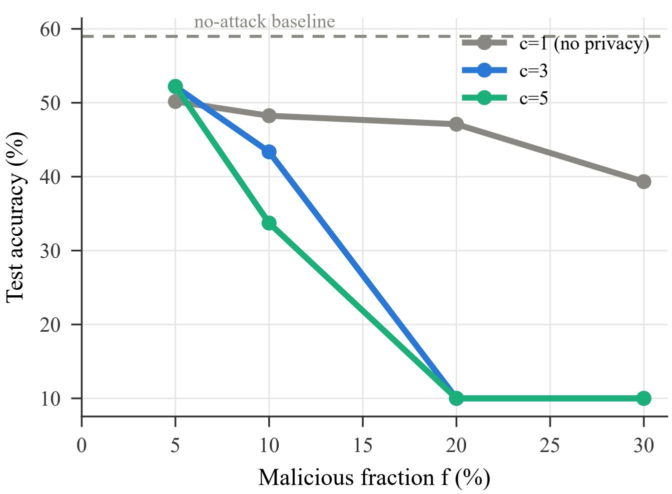

Fig. 8. The privacy–robustness dial, measured: median-rule accuracy under sign-flip for $c \in \{1, 3, 5\}$. Larger anonymity sets shift the breakdown frontier left, as $(1-f)^c$ predicts; at f=5% privacy costs nothing.